

LockonDocs - Production Readiness Plan

Overview

Field	Value
Document	Production Readiness Plan
Owner	Developer (Eazi-Business, UK)
Client	Tracey, YoWAD Tech (USA)
Status	Active planning + Phase 2 build in progress
Data sensitivity	High (PII, medical, school records)
Target infra	US-based (storage + compute)

This document tracks the work required to take LockonDocs from the accepted Phase 1 proof of concept to a full production release for a US client. It is a living document: update it as items are completed, and keep the build log in `build_state.md` in step.

Where the app stands today (end of Phase 1)

The Phase 1 build is a solid, secure foundation:

- **Authentication:** email and password, bcrypt-hashed passwords, JWT sessions via the auth layer.
- **Per-user isolation:** every data route (documents, folders, presigned upload) reads the user from the session, rejects unauthenticated calls with 401, and re-verifies folder ownership before attaching a document. No cross-user access path was found.
- **Storage:** documents are stored privately in S3 and served only through short-lived signed URLs (1 hour). SVG inline rendering is blocked (script-injection defence) and filenames are sanitised.
- **Data model:** users, folders, documents with soft-delete on the user, storage tracking, and sensible indexes.
- **GoodBarber embed:** the app loads in the embed, and the landing screen's "Access My Vault" breaks out to a top-level browser context so login cookies work first-party. Confirmed working by the client.

Accepted risk: encryption at rest

The client has chosen not to fund a dedicated encryption-at-rest work item at this stage. Note the following so the decision is on record:

- AWS S3 encrypts new objects by default with SSE-S3 (AES-256) at the platform level, so there is very likely a baseline of at-rest encryption already in place without any app change.
- LockonDocs does not currently request explicit SSE-KMS (customer-managed keys) or perform app-level (envelope) encryption.

- Recommended minimum to confirm during cutover (no build cost): verify in the AWS console that the production bucket has default encryption enabled and “Block all public access” switched on.
- If Tracey later wants stronger guarantees (auditable customer-managed keys, or documents unreadable even to an infrastructure operator), this can be revisited as a costed change. It is deferred, not forgotten.

Phase 2 - Full Feature Build

Agreed price: £2,000 (~\$2,540 USD). Scope below combines the proposal’s Phase 2 features with the production hardening agreed in planning (encryption-at-rest excluded per client decision).

Functional features

- ☐ Folder rename
- ☐ Move documents between folders
- ☐ Document search (by name)
- ☐ Document sorting (by date, by name)
- ☐ Admin panel driven by the existing `isAdmin` flag (user list, storage overview, basic controls)
- ☐ Enhanced image processing: crop, rotate, multi-page capture, PDF export
- ☐ Custom folder icons (graphics to be supplied by Tracey - blocked on assets)

Production hardening (folded into Phase 2)

- ☐ Password policy (minimum strength enforced on signup and change)
- ☐ Password reset flow (email a time-limited reset link)
- ☐ Email verification (optional, on by default for new signups)
- ☐ Login rate limiting + temporary lockout after repeated failures
- ☐ Server-side enforcement of upload file type and size
- ☐ Server-side enforcement of per-user storage quota
- ☐ Audit log of key actions (login, document view, delete, account deletion)
- ☐ Two-factor authentication (optional, deferred unless Tracey requests it - noted for scope)

Privacy and consumer rights (US)

- ☐ “Download my data” export (documents + metadata)
- ☐ Genuine “delete my account and all documents” flow (purges S3 objects + DB records)

Phase 3 - GoodBarber Production Integration

Agreed price: £500 (~\$635 USD).

- ☐ Confirm session behaviour on the new production URL
- ☐ Decide whether GoodBarber auth pass-through is wanted (if GoodBarber issues tokens)
- ☐ Cross-origin and cookie behaviour pass on real iOS and Android devices
- ☐ Confirm camera and scanning work through the production embed on real devices

Phase 4 - Launch Prep (Optional)

Agreed price: £300 (~\$380 USD).

- ☐ Performance optimisation pass

- ☐ Final security review
- ☐ User acceptance testing with Tracey
- ☐ Production go-live

Security and compliance considerations (US client)

These are considerations for the developer and Tracey to confirm. They are not legal advice; where a legal question is flagged, get it confirmed rather than assumed.

Authentication hardening

- Rate limiting and lockout on login and signup to slow brute-force attempts.
- Password reset and a sensible password policy.
- Optional two-factor authentication given the data sensitivity.
- Session cookies confirmed secure and correctly scoped on the production domain.

Access and abuse controls

- Server-side validation of upload content type and size (do not trust the client).
- Enforcement of the per-user storage quota (`storageUsed` is tracked today but not enforced).
- Audit log of sensitive actions for security and any later compliance request.

US regulatory considerations

- **Data residency:** keep storage and compute in US regions. Verify the production S3 region and database region are both US.
- **CCPA / CPRA (California):** consumers have rights to access and delete their personal data. A data export and a real account+documents deletion flow cover most of this and are good practice regardless of state.
- **Breach notification:** all US states have breach-notification laws. An audit log and a documented incident process help here.
- **COPPA:** the app can hold children's school records. If under-13s use it, or parents store children's data, COPPA may apply. Confirm with Tracey.
- **HIPAA:** most likely does not apply, because HIPAA governs healthcare providers and their business associates, not individuals storing their own medical documents in a personal vault. Because a "Medical" folder is prominent, get this confirmed rather than assumed.
- **Policy documents:** a short written data-handling and retention policy will help with app-store review and user trust.

Production cutover checklist

When the new production URL and delegate access are available:

- ☐ Point the app at the new production domain
- ☐ Provision production database in a US region
- ☐ Provision production S3 bucket in a US region, with default encryption + block-public-access confirmed
- ☐ Move all secrets into the production environment (never in client-side code or the repo)
- ☐ Run the schema migration against the production database
- ☐ Verify default-folder creation for new users
- ☐ Verify signed-URL generation against the production bucket

- [] Configure the custom-domain email sender for password reset / notifications once the domain is live
- [] Full end-to-end test inside the GoodBarber app on real iOS and Android devices
- [] Confirm login, scan, save, view, search, and delete all work in the production embed

Open decisions (need input)

- **Two-factor authentication:** in or out for launch?
 - **Email verification:** required before first login, or soft (allow login, nudge to verify)?
 - **COPPA / HIPAA applicability:** confirm with Tracey given the data types.
 - **Custom folder icons:** awaiting graphics from Tracey.
-

Last updated: 2026-07-19. Keep this in step with `build_state.md` .